

Marco Integrativo GQM + PRAGMATIC para Indicadores GCI

1. Contexto y propósito

Este marco integra tres piezas que rara vez se sientan juntas en la misma mesa:

- El Global Cybersecurity Index (GCI) de la UIT, con sus cinco pilares de compromiso nacional en ciberseguridad.[web:20]
- La metodología Goal–Question–Metric (GQM), que obliga a que toda métrica responda a una pregunta y toda pregunta apunte a un objetivo.[web:42][web:43][web:54]
- El criterio PRAGMATIC de evaluación de métricas (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable).[web:47][web:50][web:55]

El resultado: un puente trazable desde los **objetivos nacionales GCI-like** (España en Tier 1, resiliencia nacional, alineamiento con España Digital 2026) hasta los **datos técnicos** que recogen las organizaciones y que queremos convertir en un Índice Global de Madurez (IGM) empresarial.

2. Recordatorio mínimo: GQM y PRAGMATIC

2.1. GQM

La aproximación GQM asume que no se debe medir nada que no responda a un propósito claro.[web:43][web:51][web:45]

- Goal (Objetivo): enunciar, desde la perspectiva de la organización o del país, qué se quiere lograr, para qué y en qué contexto.
- Question (Pregunta): traducir el objetivo en preguntas evaluables que orienten la observación.
- Metric (Métrica): definir indicadores cuantitativos o cualitativos que permitan responder a las preguntas de forma sistemática.

En nuestro caso:

- Los Goals derivan de los cinco pilares del GCI y de objetivos nacionales (ej. España Digital 2026, NIS2, ENS).[web:20][web:39]
- Las Questions se inspiran en el cuestionario GCIv5 y en marcos de madurez de seguridad aplicados a empresas.[web:20][web:35][web:41]
- Las Metrics son datos operativos que las organizaciones pueden recoger sin tener que recurrir a oráculos.

2.2. PRAGMATIC

El enfoque PRAGMATIC propone que toda métrica de seguridad se valore según nueve criterios:[web:47][web:50][web:55]

- P – Predictivo: ¿ayuda a anticipar problemas antes de que estallen?

- R – Relevante: ¿importa realmente para los objetivos de la organización / país?
- A – Accionable: ¿sugiere decisiones concretas o cambios claros?
- G – Genuino: ¿refleja la realidad o puede manipularse con facilidad?
- M – Significativo (Meaningful): ¿es comprensible para quien debe usarla?
- A – Preciso (Accurate): ¿es fiable y consistente en el tiempo?
- T – Oportuno (Timely): ¿llega a tiempo para influir en decisiones?
- I – Independiente: ¿no depende en exceso de una fuente o persona parcial?
- C – Rentable (Cheap): ¿su coste de obtención es razonable frente al valor que aporta?

En este marco, cada métrica asociada a los indicadores del GCI se acompaña de una pequeña “tarjeta PRAGMATIC” que permite decidir si merece la pena mantenerla o ajustarla.

3. Arquitectura del marco: de GCI a IGM

3.1. Capas de abstracción

Proponemos una arquitectura de cuatro capas:

1. Objetivos nacionales GCI-like (macro)
2. Derivados de la posición y aspiraciones de España en el GCI (Tier 1, resiliencia, cooperación internacional).[web:9][web:20]
3. Vinculados a programas como España Digital 2026 (por ejemplo, “reforzar la ciberseguridad del tejido productivo”).[web:39]
4. Objetivos intermedios por pilar (meso)
5. Traducen cada pilar GCI a metas específicas para empresas (ej. “mejorar la gestión contractual de ciberseguridad” en el pilar legal).
6. Preguntas GQM (micro estratégico)
7. Formuladas en lenguaje de negocio/gestión (ej. “¿tenemos cláusulas de ciberseguridad adecuadas en nuestros contratos críticos?”).
8. Métricas técnicas (micro operativo)
9. Datos concretos que responden a las preguntas (ej. “% de contratos con cláusulas de seguridad estándar aprobadas”).

Vinculados a programas como España Digital 2026 (por ejemplo, “reforzar la ciberseguridad del tejido productivo”).[web:39]

Objetivos intermedios por pilar (meso)

Traducen cada pilar GCI a metas específicas para empresas (ej. “mejorar la gestión contractual de ciberseguridad” en el pilar legal).

Preguntas GQM (micro estratégico)

Formuladas en lenguaje de negocio/gestión (ej. “¿tenemos cláusulas de ciberseguridad adecuadas en nuestros contratos críticos?”).

Métricas técnicas (micro operativo)

Cada métrica se evalúa con PRAGMATIC, de forma que el sistema pueda depurarse con el tiempo: se mantienen las métricas altas en PRAGMATIC, se revisan o eliminan las métricas débiles.

3.2. Correspondencia con el GCI

El GCI estructura su cuestionario en 5 pilares, 20 indicadores y diversos subindicadores que abarcan leyes, políticas, CSIRT, formación, cooperación, etc.[web:20] Para trasponerlo al nivel empresarial, proponemos cinco **macro-objetivos**:

- G1 – Fortaleza jurídica corporativa (Pilar Legal).
- G2 – Capacidad técnica de protección, detección y respuesta (Pilar Técnico).
- G3 – Gobernanza y gestión del riesgo (Pilar Organizativo).
- G4 – Capacidades humanas y de aprendizaje (Pilar Desarrollo de capacidades).
- G5 – Cooperación y ecosistema (Pilar Cooperación).

Cada uno se descompone en 2–4 **sub-objetivos GQM**, que a su vez generan bloques de preguntas y métricas.

4. Ejemplos de cadenas GQM por pilar

4.1. Pilar Legal (G1)

Goal G1.1: Asegurar que la organización cumple de forma efectiva con las obligaciones legales y regulatorias en materia de ciberseguridad y protección de datos.

Questions (ejemplos)

- Q1.1.1: ¿Identifica y mantiene la organización un inventario actualizado de normativas aplicables?
- Q1.1.2: ¿Se realizan y siguen análisis de brechas de cumplimiento?
- Q1.1.3: ¿Los contratos con terceros reflejan adecuadamente los requisitos de ciberseguridad?

Metrics (ejemplos)

- M1.1.1: Existencia de inventario normativo formal (sí/no; madurez 0–4).

- M1.1.2: Nº de análisis de brecha realizados en los últimos 24 meses.
- M1.1.3: % de contratos críticos que incluyen cláusulas de ciberseguridad definidas.
- M1.1.4: % de hallazgos de cumplimiento con plan de acción asignado y en curso.

Cada métrica se somete a la rejilla PRAGMATIC (ver matriz en el fichero correspondiente).

4.2. Pilar Técnico (G2)

Goal G2.1: Aumentar la capacidad de la organización para prevenir, detectar y responder eficazmente a ciberincidentes que puedan afectar a servicios esenciales o datos críticos.

Questions (ejemplos)

- Q2.1.1: ¿Conocemos nuestros activos críticos y su exposición?
- Q2.1.2: ¿Disponemos de capacidades de monitorización y respuesta adecuadas al riesgo?
- Q2.1.3: ¿Probamos regularmente la eficacia de copias de seguridad y recuperaciones?

Metrics (ejemplos)

- M2.1.1: % de activos críticos inventariados respecto al total estimado.
- M2.1.2: Porcentaje de activos críticos cubiertos por monitorización 24x7.
- M2.1.3: Tiempo medio de detección (MTTD) de incidentes significativos.
- M2.1.4: Tiempo medio de respuesta (MTTR) hasta contención.
- M2.1.5: Nº de pruebas de restauración de backups críticas realizadas / año y porcentaje exitoso.

4.3. Pilar Organizativo (G3)

Goal G3.1: Integrar la ciberseguridad en la gobernanza corporativa y en la gestión de riesgos y continuidad de negocio.

Questions (ejemplos)

- Q3.1.1: ¿Existe una estrategia de ciberseguridad alineada con la estrategia de negocio?
- Q3.1.2: ¿Participa el órgano de gobierno en la supervisión de la ciberseguridad?
- Q3.1.3: ¿Se realizan ejercicios de crisis y pruebas de continuidad que incluyan ciberincidentes?

Metrics (ejemplos)

- M3.1.1: Existencia de estrategia formal de ciberseguridad (madurez 0–4).
- M3.1.2: Nº de sesiones de consejo / dirección con reporte de ciberseguridad por año.
- M3.1.3: Nº de ejercicios de crisis con componente ciber / año.
- M3.1.4: % de procesos críticos cubiertos por BCP/DRP que incluyen escenarios de ciberincidente.

4.4. Pilar Desarrollo de Capacidades (G4)

Goal G4.1: Fortalecer el capital humano en ciberseguridad, tanto especializado como generalista, para asegurar la sostenibilidad de las capacidades.

Questions (ejemplos)

- Q4.1.1: ¿Reciben los empleados formación periódica en ciberseguridad?

- Q4.1.2: ¿Cuenta la organización con un equipo de ciberseguridad dimensionado y cualificado?
- Q4.1.3: ¿Existe un plan de carrera y certificaciones para perfiles clave?

Metrics (ejemplos)

- M4.1.1: % de empleados que completan formación de ciberseguridad anual.
- M4.1.2: N° de profesionales dedicados a ciberseguridad por 1000 empleados.
- M4.1.3: N° medio de certificaciones relevantes por miembro del equipo de ciberseguridad.
- M4.1.4: Rotación anual del personal de ciberseguridad (%).

4.5. Pilar Cooperación (G5)

Goal G5.1: Aumentar el grado de cooperación y compartición de información de la organización con el ecosistema de ciberseguridad.

Questions (ejemplos)

- Q5.1.1: ¿Participa la organización en foros y redes sectoriales de ciberseguridad?
- Q5.1.2: ¿Comparte información sobre amenazas e incidentes con terceros de confianza?
- Q5.1.3: ¿Realiza ejercicios conjuntos con proveedores y autoridades?

Metrics (ejemplos)

- M5.1.1: N° de redes / foros de ciberseguridad en los que participa activamente la organización.
- M5.1.2: N° de notificaciones de incidentes relevantes a CSIRT / autoridades / redes sectoriales por año.
- M5.1.3: N° de ejercicios conjuntos con terceros al año.

5. Uso práctico del marco

10. Definir objetivos nacionales y sectoriales

11.

Tomar como referencia el GCI, estrategias nacionales y sectoriales para priorizar pilares y sub-objetivos.[web:20][web:39]

12.

Seleccionar y refinar preguntas GQM

13.

Partir del banco de preguntas de la encuesta y de los ejemplos de este marco.

14.

Seleccionar métricas GQM-PRAGMATIC

15. Para cada pregunta, definir 1-3 métricas potenciales.

16.

Evaluar cada métrica con la matriz PRAGMATIC (ver fichero específico).

17.

Depurar el catálogo de métricas

18. Retener métricas con buena puntuación global PRAGMATIC.

19.

Ajustar o descartar las que son bonitas en teoría y tóxicas en la práctica (por coste, manipulación, ausencia de acción).

20.

Mantener la trazabilidad

21. Documentar siempre el encadenamiento Goal-Question-Metric en una tabla (objetivo nacional → objetivo pilar → pregunta → métrica → PRAGMATIC).

Tomar como referencia el GCI, estrategias nacionales y sectoriales para priorizar pilares y sub-objetivos.
[web:20][web:39]

Seleccionar y refinar preguntas GQM

Partir del banco de preguntas de la encuesta y de los ejemplos de este marco.

Seleccionar métricas GQM-PRAGMATIC

Evaluar cada métrica con la matriz PRAGMATIC (ver fichero específico).

Depurar el catálogo de métricas

Ajustar o descartar las que son bonitas en teoría y tóxicas en la práctica (por coste, manipulación, ausencia de acción).

Mantener la trazabilidad

Con este marco, cada dato técnico deja de ser un número suelto y pasa a ser un eslabón en una cadena que empieza en los objetivos nacionales de seguridad y termina en los logs y formularios de las organizaciones.